

Manual 04 - Implementación del Perfil de IA Generativa NIST AI 600-1

CANDIDATO CONTROLADO PARA QA DE PUBLICACION

Revisión de fuente controlada: 2b1e27f06c1f35ff2b95b8b528a30aae4682bd5d | Idioma: es-419 | Perfil de IA Generativa NIST AI 600-1 con el marco principal AI RMF 1.0; control de versiones y vigilancia de fuentes.

Límite de aseguramiento: Este manual voluntario de implementación no certifica un sistema de IA generativa, no establece cumplimiento legal, no demuestra por sí solo una IA confiable ni proporciona una opinión de auditoría; no todas las acciones sugeridas aplican a cada actor, sistema, caso de uso o contexto del ciclo de vida.

Rutas de implementación y modelo operativo

Manual 04 - rutas de implementacion

Proposito y limite de control

Esta incorporacion convierte NIST AI 600-1 en trabajo de implementacion escalable sin transformar las acciones sugeridas de caracter voluntario en requisitos universales. Cada organizacion debe determinar la aplicabilidad a partir de su inventario de IA generativa (GAI), las tareas de los actores de IA, la etapa del ciclo de vida, el contexto de uso, las partes afectadas, la tolerancia al riesgo, las obligaciones aplicables y los recursos.

Las tres rutas modifican la profundidad, independencia, frecuencia y evidencia esperadas. No modifican la necesidad de comprender el riesgo material de GAI, asignar decisiones responsables, detener o revertir un uso inaceptable, responder a incidentes y conservar evidencia defendible.

1. Seleccionar una ruta proporcional

Ruta esencial

Usela cuando la huella de GAI sea limitada, la organizacion sea pequena, los casos de uso tengan baja complejidad y no se haya identificado un impacto material de seguridad, derechos, servicios criticos, datos altamente sensibles, alta capacidad o informacion publica a gran escala.

Conjunto operativo minimo:

- ejecutivo u propietario designado para el riesgo de GAI;
- inventario de modelos, servicios, integraciones, casos de uso, usuarios y datos aprobados;
- reglas de uso aceptable y uso prohibido;
- evaluacion de las doce familias de riesgo de GAI;
- controles basicos de privacidad, seguridad, propiedad intelectual, contenido y proveedores;
- revision humana documentada para resultados con consecuencias relevantes;
- criterios definidos de liberacion, detencion, reversion y escalamiento de incidentes;
- monitoreo periodico y reevaluacion despues de cambios materiales; y
- un registro de evidencia que vincule decisiones, pruebas, hallazgos, remediacion y riesgo residual.

Ruta estructurada

Usela cuando participen multiples sistemas de GAI o unidades de negocio, existan datos sensibles o procesos regulados, los resultados orientados a clientes sean materiales, las dependencias de terceros sean significativas o la organizacion necesite aseguramiento repetible.

Agregue a la ruta Esencial:

- foro formal de gobernanza de GAI y mapa de actores/responsabilidades;
- registro de aplicabilidad y adaptacion accion por accion;
- evaluaciones de riesgo a nivel de modelo, sistema, caso de uso y ecosistema;
- plan de TEVV previo al despliegue y red teaming basado en riesgo;

- controles de procedencia de contenido e integridad de la informacion;
- retroalimentacion representativa de usuarios y partes afectadas;
- debida diligencia de proveedores, clausulas contractuales, monitoreo y planes de salida documentados;
- revision independiente de decisiones de liberacion de mayor riesgo;
- metricas, umbrales, alertas, divulgacion de incidentes y flujo de acciones correctivas definidos; y
- revision programada de efectividad de controles e informes a la gerencia.

Ruta mejorada

Usela para GAI de alta capacidad o ampliamente desplegada, exposicion material de seguridad nacional o CBRN, contextos criticos para la seguridad o servicios esenciales, decisiones de alto impacto, poblaciones vulnerables, efectos de integridad de informacion a gran escala, propiedad intelectual de alto valor o cadenas de valor complejas.

Agregue a la ruta Estructurada:

- evaluacion tecnica y de dominio independiente;
- pruebas adversariales contra modelos de amenaza y casos de uso indebido realistas;
- entornos de evaluacion controlados y datos de prueba protegidos;
- analisis cuantitativo y cualitativo de incertidumbre;
- monitoreo continuo de deriva, cambios de capacidad, uso indebido emergente y fallas correlacionadas;
- separacion de desarrollo, validacion, liberacion y aprobacion del riesgo residual;
- procedimientos ensayados de contencion, apagado de modelo/servicio, alternativa y recuperacion;
- monitoreo mejorado del uso posterior y del ecosistema;
- planes formales de comunicacion con partes afectadas, reguladores, clientes y proveedores; y
- supervision de la junta directiva o equivalente para riesgos que excedan la tolerancia delegada.

Gráfico de memoria del Manual 04 1

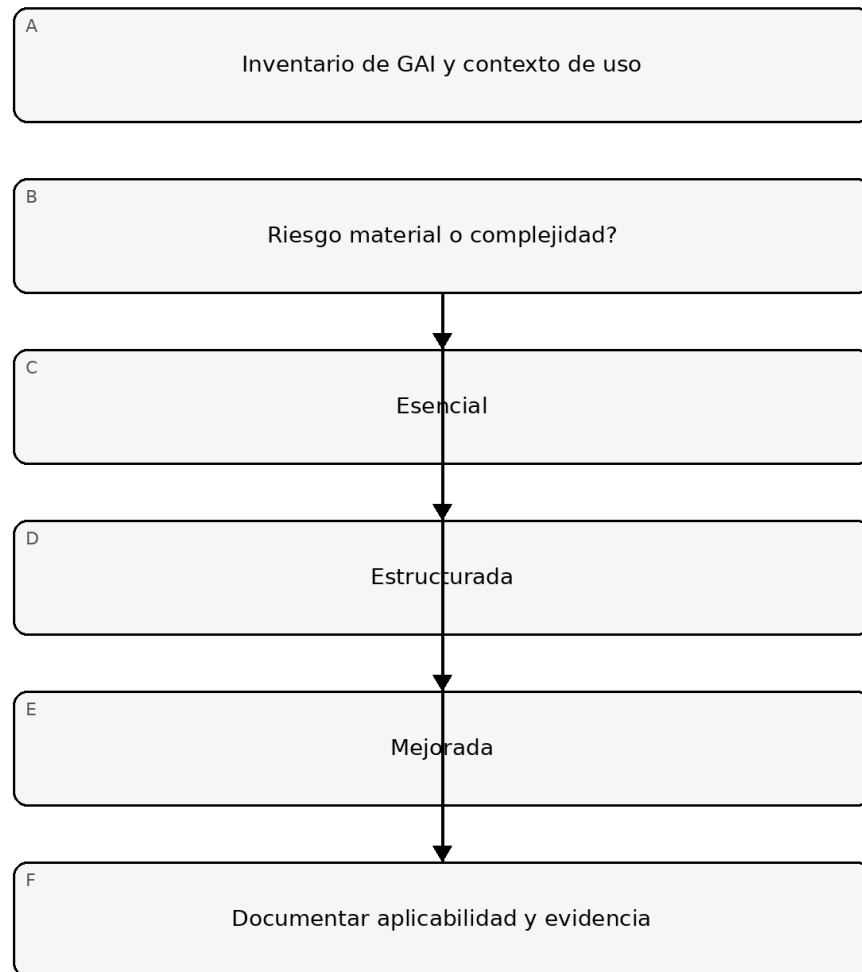


Figura 1. Gráfico de memoria de implementación

Explicación accesible: Comience con el inventario de GAI y el contexto real. Los usos bajos y acotados pueden emplear controles Esenciales; los usos múltiples o sensibles necesitan controles Estructurados; los usos de alta capacidad o alto impacto necesitan controles Mejorados. Cada ruta termina en una decisión documentada de aplicabilidad y evidencia.

2. Operar el perfil mediante el núcleo del AI RMF

GOVERN

Establezca la autoridad y las condiciones para utilizar GAI:

- asigne responsables y tareas de actores de IA;
- defina tolerancia al riesgo, usos prohibidos, uso aceptable, escalamiento y excepciones;
- integre obligaciones legales, de privacidad, seguridad, seguridad física, propiedad intelectual, registros, adquisiciones e incidentes;
- exija competencia e independencia apropiadas para la decisión;
- defina controles para proveedores, código abierto, modelos, herramientas, plugins, recuperación y uso posterior;
- proteja a denunciantes y canales para reportar riesgos o daños fundamentados;
- establezca retención documental, trazabilidad de decisiones y control de cambios; y
- exija aprobación explícita antes del desarrollo, despliegue, expansión o cambio material de configuración.

MAP

Describe el sistema real y el contexto antes de medirlo:

- distinga el modelo base, ajuste fino, recuperacion, instrucciones de prompt/sistema, herramientas, agentes, logica de aplicacion, interfaz de usuario y consumidores posteriores;
- identifique proposito previsto, uso y uso indebido razonablemente previsibles, usuarios, no usuarios y partes afectadas;
- mapee fuentes de datos y contenido, derechos, consentimiento, sensibilidad, procedencia, transformaciones, retencion y eliminacion;
- mapee proveedores ascendentes, componentes de codigo abierto, API, alojamiento, monitoreo y dependencias de contingencia;
- evalúe el riesgo en los niveles de modelo, sistema, caso de uso y ecosistema;
- registre supuestos, limitaciones, incertidumbre, beneficios, impactos negativos y concentracion de riesgo; y
- determine cuales de las doce familias de riesgo de GAI son materiales, monitoreadas, diferidas o no aplicables, con sus razones.

MEASURE

Utilice metodos proporcionales al riesgo y a la afirmacion evaluada:

- valide afirmaciones de capacidad y desempeno bajo condiciones representativas;
- pruebe confabulacion, confiabilidad de fuentes/citas y comunicacion de incertidumbre;
- evalúe filtracion de privacidad, memorizacion, inferencia y manejo de datos sensibles;
- pruebe seguridad de la informacion, inyeccion de prompts, envenenamiento de datos, robo de modelos, uso indebido de herramientas y autonomia insegura;
- evalúe sesgo perjudicial, homogeneizacion, contenido peligroso, contenido abusivo y configuracion humano-IA;
- realice evaluacion basada en riesgo de capacidades CBRN y ciberofensivas cuando sea pertinente y este autorizada;
- evalúe procedencia de contenido, etiquetado, marcas de agua, metadatos, limites de deteccion y cadena de custodia;
- evalúe riesgos de propiedad intelectual y derechos sobre datos;
- mida impactos de recursos y ambientales cuando sean materiales;
- utilice red teaming, retroalimentacion humana estructurada, pruebas de campo o evaluacion independiente segun corresponda;
- registre alcance de pruebas, conjuntos de datos, entorno, umbrales, limitaciones, fallas y remediacion; e
- incluya en la decision de riesgo residual los riesgos que no puedan medirse cuantitativamente, en lugar de tratarlos como cero.

MANAGE

Convierta la evidencia en accion responsable:

- priorice por contexto, probabilidad o incertidumbre, magnitud, escala, partes afectadas, reversibilidad y tolerancia organizacional;
- seleccione tratamientos de prevencion, deteccion, respuesta, recuperacion, transferencia, evitacion, aceptacion o discontinuacion;
- defina decisiones de seguir, seguir condicionado, no seguir, detener, revertir, contener y retirar;
- asigne responsables y fechas limite de remediacion;
- monitoree cambios de modelo, sistema, uso, proveedor, datos, contenido y ecosistema;
- active reevaluacion despues de una nueva capacidad, ajuste fino, cambio de recuperacion, acceso a herramientas, expansion del despliegue, incidente, cambio de proveedor o cambio regulatorio;
- divulgue incidentes a las partes internas y externas apropiadas conforme a las obligaciones aplicables;
- preserve evidencia y comunique limitaciones a actores posteriores y partes afectadas; y
- verifique la accion correctiva y retroalimente las lecciones a GOVERN y MAP.

Gráfico de memoria del Manual 04 2

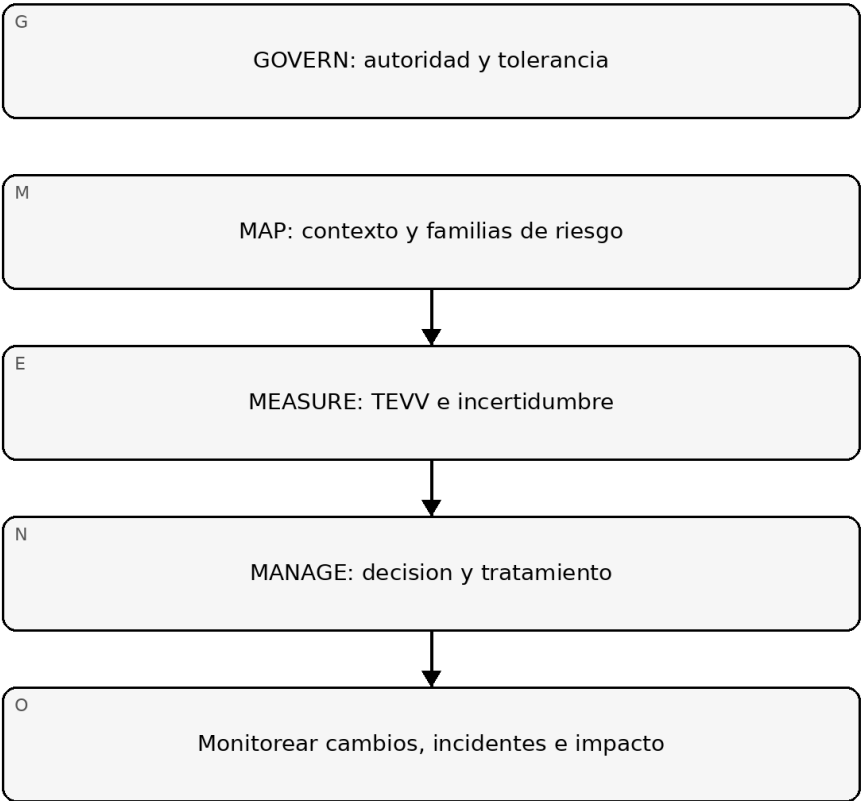


Figura 2. Gráfico de memoria de implementación

Explicacion accesible: La gobernanza establece autoridad y tolerancia; el mapeo establece el contexto y los riesgos de GAI pertinentes; la medicion produce evidencia de pruebas e incertidumbre; la gestion toma y hace cumplir decisiones. El monitoreo devuelve a la gobernanza la informacion sobre cambios, incidentes e impactos.

3. Evaluar las doce familias de riesgo

Para cada modelo, sistema, aplicacion o caso de uso, registre una disposicion para cada familia:

Familia de riesgo	Pregunta minima de implementacion	Ejemplo de evidencia
Informacion o capacidades CBRN	Podria el sistema reducir materialmente las barreras para actividades biologicas, quimicas, radiologicas o nucleares daninas?	Pruebas de capacidad autorizadas, limites de acceso, registros de escalamiento
Confabulacion	Podria una salida falsa o no respaldada provocar decisiones materiales, danos o perdidas?	Pruebas de grounding, controles de citas, umbrales de revision humana
Contenido peligroso, violento o de odio	Pueden las entradas o salidas facilitar violencia, odio, extremismo o actividades peligrosas?	Evaluaciones de seguridad, resultados de moderacion, monitoreo de uso indebido
Privacidad de datos	Pueden el entrenamiento, la recuperacion, los prompts, los registros o las salidas exponer o inferir datos sensibles?	Mapa de flujo de datos, pruebas de privacidad, evidencia de retencion y eliminacion
Impactos ambientales	Son materiales para la decision los	Estimaciones de energia/recursos,

Familia de riesgo	Pregunta minima de implementacion	Ejemplo de evidencia
	impactos de recursos del entrenamiento o inferencia?	decisiones de eficiencia, monitoreo
Sesgo perjudicial y homogeneizacion	Generan las salidas danos dispares, fallas correlacionadas o menor diversidad?	Pruebas por subpoblacion, retroalimentacion de partes afectadas, resultados de mitigacion
Configuracion humano-IA	Podrian los usuarios depender en exceso, malinterpretar, antropomorfizar o perder supervision efectiva?	Pruebas de UX, instrucciones, evidencia de carga de trabajo y anulacion
Integridad de la informacion	Puede el contenido generado socavar procedencia, autenticidad, confianza publica o decisiones?	Diseno de procedencia, pruebas de etiquetado, divulgacion y monitoreo
Seguridad de la informacion	Puede el sistema ser atacado o utilizado indebidamente mediante prompts, datos, modelos, herramientas, API o agentes?	Modelo de amenazas, resultados de red team, controles de acceso y registro
Propiedad intelectual	Son inciertos o se infringen los derechos de entrenamiento, entrada, salida o distribucion?	Registro de derechos, analisis contractual, controles de revision de salidas
Contenido obsceno, degradante y/o abusivo	Puede el sistema crear o amplificar contenido sexual, degradante, explotador o abusivo?	Pruebas de seguridad, moderacion, proceso de reporte y apoyo a victimas
Cadena de valor e integracion de componentes	Pueden las dependencias ascendentes o posteriores crear riesgo opaco, concentrado o en cascada?	Inventario de proveedores, contratos, avisos de cambio, pruebas de contingencia

No se puede omitir ninguna familia. No aplicable requiere una justificacion registrada y un disparador de reconsideracion. Una familia puede ser material en un nivel y no en otro; por ejemplo, un riesgo del modelo base puede controlarse en la capa de aplicacion mientras la dependencia del ecosistema permanece.

4. Adaptar las acciones sugeridas sin perder responsabilidad

Utilice un registro de aplicabilidad con estos campos:

- ID de accion NIST y subcategoria del AI RMF;
- familias de riesgo de GAI pertinentes;
- tareas aplicables de actores de IA;
- alcance de modelo, sistema, caso de uso y ecosistema;
- disposicion: adoptar, adaptar, control equivalente, diferir o no aplicable;
- justificacion y fuente del requisito;
- responsable y autoridad aprobadora;
- evidencia de implementacion;
- prueba de efectividad y resultado;
- riesgo residual y fecha de vencimiento/revision; y
- cambios o incidentes que reabren la decision.

Un control equivalente debe lograr el mismo objetivo de riesgo en el contexto real. El diferimiento debe indicar la brecha de evidencia, el control interino, el responsable, la fecha limite y la exposicion aceptada. Las decisiones de no aplicabilidad no deben utilizarse para evitar un riesgo material pero dificil de medir.

5. Definir compuertas de liberacion y operacion

Antes del despliegue o una expansion material, exija evidencia de que:

- los usos previstos y previsibles estan documentados;
- se evaluaron las familias de riesgo pertinentes;
- las pruebas requeridas cumplieron los umbrales aprobados;
- los hallazgos criticos y altos estan resueltos o fueron rechazados explicitamente mediante aceptacion de riesgo autorizada;
- la supervision humana es competente, disponible y efectiva;
- los riesgos de proveedores y componentes estan dentro de tolerancia;

- los controles de procedencia de contenido y divulgacion son adecuados para el proposito;
- el monitoreo, divulgacion de incidentes, detencion, reversion y contingencia estan operativos;
- los usuarios y actores posteriores reciben las limitaciones e instrucciones necesarias; y
- el riesgo residual esta aprobado por la autoridad correcta.

Los disparadores de detencion o reversion deben incluir incumplimiento de umbral, nueva capacidad peligrosa, falla de control, evento material de privacidad/seguridad, salida danina repetida, supervision no confiable, perdida de proveedor, deriva inexplicada, incidente grave o evidencia de que el uso real difiere materialmente del contexto aprobado.

6. Preservar el ciclo de evidencia y decision

Gráfico de memoria del Manual 04 3

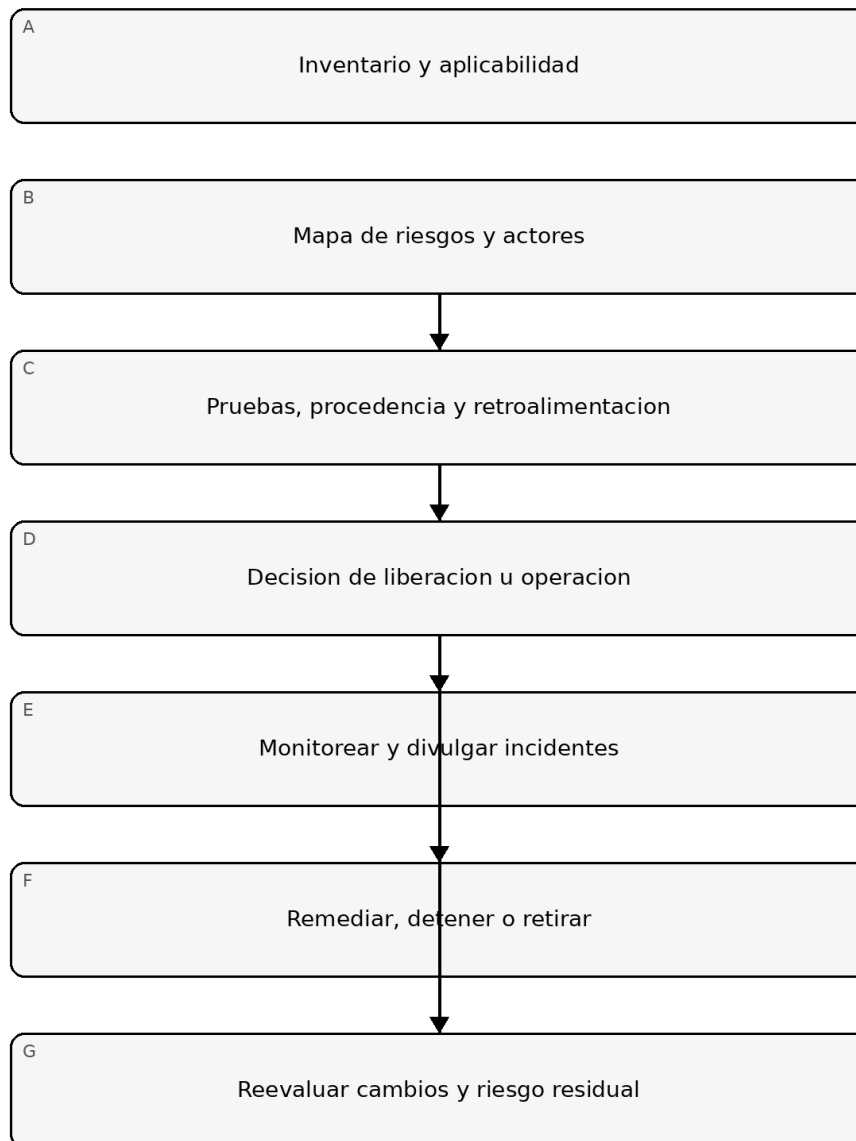


Figura 3. Gráfico de memoria de implementación

Explicación accesible: El ciclo de evidencia comienza con inventario y aplicabilidad, luego mapea riesgos y actores, recopila pruebas y retroalimentación y llega a una decisión responsable. El uso aprobado o condicionado se monitorea; el uso rechazado se remedia, detiene o retira. La reevaluación de cambios y riesgo residual reinicia el ciclo.

7. Criterios de finalizacion para analistas y gerentes

Un analista debe poder mostrar:

- la fuente NIST exacta y la version controlada utilizada;
- los limites pertinentes de modelo/sistema/caso de uso/ecosistema;
- la disposicion de cada familia de riesgo;
- evidencia de aplicabilidad y adaptacion de acciones;
- trazabilidad de fuente a control, prueba y decision;
- supuestos, limitaciones y brechas de evidencia abiertas; y
- registros de monitoreo, incidentes y reevaluacion.

Un gerente debe poder responder:

- quien es dueno del riesgo y quien puede aprobar, detener o revertir el sistema;
- cuales danos o fallas exceden la tolerancia;
- que evidencia respalda la decision y que sigue siendo incierto;
- si la supervision humana y los controles de proveedores funcionan en la practica;
- como se protege e informa a las partes afectadas y actores posteriores;
- que cambios invalidan la aprobacion; y
- si el riesgo residual sigue siendo aceptable.

Declaracion de aseguramiento

Esta incorporacion de implementacion apoya el uso controlado y basado en evidencia de NIST AI 600-1. No certifica un sistema, no sustituye la ley o contrato aplicable, no demuestra que todas las acciones sugeridas sean aplicables, no establece cumplimiento legal y no proporciona una opinion de auditoria. Los revisores humanos y los responsables autorizados siguen siendo responsables de la aplicabilidad, la semantica, la aceptacion del riesgo y la liberacion.

Manual controlado de 32 capítulos

Capítulo 01 — Propósito, alcance y aplicabilidad

Este manual operacionaliza la gestión de riesgos de IA generativa para organizaciones que diseñan, adquieren, integran, despliegan, operan o retiran capacidades de IA generativa. El límite de implementación es deliberadamente basado en riesgo: no todos los controles, pruebas, elementos de evidencia o prácticas operativas aplican a todos los casos de uso.

Cada implementación comienza con una decisión documentada de aplicabilidad que cubra el caso de uso, las partes afectadas, el contexto de despliegue, los datos tratados, el nivel de autonomía, las dependencias externas y las consecuencias de error o uso indebido. El registro de aplicabilidad se convierte en evidencia controlada y debe revisarse cuando cambien de manera material el sistema, modelo, datos, herramientas, proveedor o contexto operativo.

Evidencia mínima:

- descripción del caso de uso y responsable de negocio;
- referencia al inventario del sistema/modelo/componente;
- identificación de partes afectadas y grupos de interés;
- nivel de riesgo o clasificación equivalente;
- fundamento de aplicabilidad;
- revisor y fecha de aprobación.

Capítulo 02 — Relación con AI RMF 1.0

NIST AI 600-1 se trata como un perfil de IA generativa y recurso complementario de AI RMF, no como una lista de verificación universal independiente. Por ello, el modelo operativo conserva GOVERN, MAP, MEASURE y MANAGE como ciclo de gestión, incorporando familias de riesgo específicas de IA generativa, expectativas de pruebas, consideraciones de procedencia y señales de incidentes.

Las organizaciones deberían mapear cada decisión de implementación de IA generativa con la función correspondiente de AI RMF y conservar trazabilidad desde la declaración de riesgo hasta la evidencia, decisión, acción y riesgo residual.

Comportamiento de control requerido:

- GOVERN establece política, responsabilidad, autoridad y escalamiento;
- MAP define contexto, uso, actores, dependencias y daños plausibles;
- MEASURE evalúa desempeño, seguridad, ciberseguridad, privacidad, integridad e incertidumbre;
- MANAGE selecciona tratamientos, acepta riesgo residual, supervisa la operación y activa detener/revertir cuando se superan los umbrales.

Capítulo 03 — Rutas de implementación

Se admiten tres rutas proporcionales.

Esencial

Para usos de menor complejidad o impacto. Requiere inventario, responsables, evaluación básica de riesgo, pruebas mínimas, supervisión humana, gestión de incidentes y aprobación documentada.

Estructurada

Para usos materiales de negocio, clientes, fuerza laboral, seguridad, privacidad, finanzas u operaciones. Requiere registros formales de riesgos, matrices de evidencia, planes de prueba, revisión de proveedores, controles de cambio, umbrales de monitoreo, guías de respuesta a incidentes y reevaluación periódica.

Reforzada

Para usos de alto impacto, alta autonomía, sensibles a la seguridad, regulados, expuestos externamente o de otra forma consecuenciales. Requiere desafío independiente, pruebas adversariales más profundas, criterios formales de liberación, mayor procedencia, autoridad explícita para detener/revertir, monitoreo reforzado y aceptación documentada del riesgo residual por la dirección responsable.

La selección de la ruta debe justificarse y solo puede reducirse mediante aprobación documentada.

Capítulo 04 — Gobernanza y responsabilidad

Todo sistema de IA generativa debe tener responsables de negocio, técnicos, de seguridad, privacidad/datos y riesgo adecuados a su alcance. La responsabilidad no puede delegarse únicamente al proveedor del modelo o al proveedor de implementación.

La gobernanza debería definir:

- quién puede aprobar un nuevo caso de uso;
- quién puede aprobar cambios de modelo, prompt, recuperación, herramientas o datos;
- quién es responsable de las pruebas y la evidencia;
- quién puede suspender o revertir el despliegue;
- quién acepta el riesgo residual;
- quién recibe notificaciones de incidentes;
- quién realiza la revisión periódica.

Deben identificarse conflictos de interés cuando la misma persona diseña, prueba y aprueba un sistema de alto impacto. Las implementaciones reforzadas deberían añadir revisión o desafío independiente.

Capítulo 05 — Inventario y descomposición del sistema

Trate la capacidad de IA generativa como un sistema, no solo como un modelo. El inventario debería identificar modelo, entorno de alojamiento, capa de recuperación, almacén vectorial, prompts/instrucciones del sistema, herramientas, API, fuentes de datos, artefactos de ajuste, guardrails, componentes de monitoreo, servicios externos y puntos de decisión humana.

El inventario debería capturar versión, responsable, proveedor, ubicación de despliegue, clasificación de datos, límite de autenticación, autoridad de cambio y estado de retiro. Las dependencias que puedan alterar materialmente la salida o el comportamiento deben ser trazables por separado.

Un cambio del sistema es material cuando puede alterar riesgo, capacidad, exposición, calidad de salida, seguridad, ciberseguridad, privacidad, postura de cumplimiento o impacto sobre partes afectadas.

Capítulo 06 — Modelo de familias de riesgo de IA generativa

La línea base controlada de Manual 04 conserva doce familias de riesgo de IA generativa:

1. Información o capacidades CBRN
2. Confabulación
3. Contenido peligroso, violento o de odio
4. Privacidad de datos
5. Impactos ambientales
6. Sesgo perjudicial y homogeneización
7. Configuración humano-IA
8. Integridad de la información
9. Seguridad de la información
10. Propiedad intelectual
11. Contenido obsceno, degradante y/o abusivo
12. Integración de cadena de valor y componentes

Estas familias son categorías de evaluación, no hallazgos automáticos. Cada caso de uso debe determinar qué familias aplican, los escenarios creíbles, los controles existentes, la evidencia, el riesgo residual y los indicadores de monitoreo.

Capítulo 07 — Declaraciones de riesgo y rutas de impacto

Los registros de riesgo deberían basarse en escenarios y no ser genéricos. Una estructura útil es:

Condición o amenaza → comportamiento del sistema → activo/persona/proceso afectado → consecuencia → control/evidencia → riesgo residual.

Por ejemplo, un asistente con recuperación puede ingerir contenido no confiable, seguir instrucciones maliciosas incrustadas, invocar una herramienta externa y exponer información restringida. La declaración de riesgo debería describir la ruta completa y no limitarse a etiquetar el problema como “prompt injection”.

El análisis de impacto debería considerar efectos directos, indirectos, acumulativos y de uso indebido previsible. Cuando los impactos sean inciertos, la incertidumbre debe registrarse en lugar de convertirse silenciosamente en una conclusión de bajo riesgo.

Capítulo 08 — Autoridad de liberación y compuertas fail-closed

Ningún caso de uso de IA generativa debería pasar a producción únicamente porque las pruebas automatizadas fueron aprobadas. La liberación requiere evidencia documentada suficiente para la ruta seleccionada, excepciones no resueltas dentro de tolerancias aprobadas, aprobación de responsables y toda revisión humana requerida.

Una compuerta de liberación debe fallar en cerrado cuando:

- falte evidencia requerida o esté desactualizada;
- las pruebas obligatorias estén incompletas o hayan fallado;
- existan hallazgos críticos abiertos sin tratamiento aprobado;
- falte una revisión humana obligatoria, haya sido rechazada o invalidada por cambio material;
- la aplicabilidad legal, de seguridad, privacidad, protección u operación esté sin resolver;
- se requiera capacidad de detener/revertir y no esté validada.

Un cambio material posterior a la aprobación reabre las revisiones y compuertas de liberación afectadas.

Capítulo 09 — Confabulación y confiabilidad de resultados

El riesgo de confabulación se gestiona mediante evaluación específica del caso de uso, no con un único porcentaje de exactitud. Los equipos deberían identificar qué afirmaciones deben ser factuales, la tasa de error aceptable, las consecuencias de falsa confianza y los controles usados cuando el modelo carece de respaldo confiable.

Los controles útiles incluyen recuperación con respaldo, visualización de fuentes, generación restringida, comportamiento de abstención, validación humana, verificaciones determinísticas posteriores y restricciones a acciones autónomas de alta consecuencia. La evidencia debería incluir conjuntos de evaluación, umbrales de aceptación, fallas observadas, ejemplos representativos, decisiones de remediación y aprobación del riesgo residual.

Capítulo 10 — Contenido dañino, abusivo y peligroso

Las organizaciones deberían definir categorías de contenido prohibido, restringido, dependiente del contexto o aceptable para el caso de uso. La política debe distinguir el tratamiento de entradas del usuario del tratamiento de salidas del modelo y abordar intentos adversariales de evadir salvaguardas.

Las pruebas deberían incluir uso esperado, uso indebido, condiciones límite, manipulación de prompts, variación multilingüe cuando corresponda y comportamiento de escalamiento. Un mecanismo de rechazo que pueda evadirse trivialmente no debe tratarse como control efectivo.

Capítulo 11 — Privacidad de datos e información sensible

La revisión de privacidad debería rastrear datos a través de prompts, almacenes de recuperación, registros, entrenamiento o ajuste, API externas, plataformas de observabilidad, canales de soporte e historial de conversaciones retenido.

El conjunto mínimo de controles debería abordar minimización, limitación de propósito, acceso, retención, eliminación, redacción, manejo de secretos, registro, tratamiento por terceros y divulgación al usuario cuando corresponda. Las pruebas deberían buscar memorización, fuga de datos, sobreexposición por recuperación, contaminación entre usuarios y divulgación no autorizada por herramientas o conectores.

Capítulo 12 — Sesgo perjudicial, homogeneización e impacto humano

La evaluación de sesgo debería vincularse con decisiones, recomendaciones, clasificaciones, contenido o experiencias producidas por el sistema. Los equipos deberían identificar poblaciones o grupos de interés que puedan experimentar tasas de falla o daños diferentes.

Los controles pueden incluir análisis de datos, pruebas de resultados, evaluación por subgrupos, escalamiento humano, flujos alternativos, monitoreo y restricciones en decisiones consecuenciales. Cuando la medición esté limitada por datos o tamaño de muestra, esa incertidumbre debe documentarse y no presentarse como evidencia de equidad.

Capítulo 13 — Configuración humano-IA y supervisión

La supervisión humana debe diseñarse, no asumirse. La organización debería determinar qué se espera que detecte la persona, qué evidencia está disponible, si dispone de tiempo y autoridad suficientes para intervenir y cómo se reducirá el sesgo de automatización.

Para usos consecuenciales, defina decisiones que el sistema puede tomar o recomendar, decisiones reservadas a humanos, disparadores de escalamiento, autoridad de anulación, registro de revisión humana, requisitos de competencia y procedimientos alternativos cuando el sistema no esté disponible o sea poco confiable.

Capítulo 14 — Integridad de la información y procedencia

Los controles de integridad deberían ayudar a distinguir información generada, recuperada, transformada y autoritativa. La procedencia debería preservarse cuando afecte materialmente confianza, revisión, atribución o uso posterior.

La evidencia puede incluir referencias de fuentes, metadatos, artefactos firmados, historial de transformaciones, identificadores de prompt/versión, registros de modelo y trazabilidad desde la salida hasta material de soporte. Las afirmaciones de procedencia deben ser limitadas: metadatos o etiquetas mejoran trazabilidad pero no prueban por sí mismos verdad o autenticidad.

Capítulo 15 — Seguridad de la información y pruebas adversariales

Las pruebas de seguridad de IA generativa deberían cubrir toda la superficie de ataque: prompts, fuentes de recuperación, bases vectoriales, endpoints de modelo, plugins/herramientas, identidades, secretos, API, interfaces, registros, capas de orquestación e integraciones con proveedores.

Las pruebas deberían incluir prompt injection directo e indirecto, uso no autorizado de herramientas, elevación de privilegios, extracción de datos sensibles, contenido malicioso de recuperación, revelación del prompt del sistema, abuso de acciones externas y escenarios de denegación o degradación cuando corresponda. Los hallazgos deben vincularse con controles, responsables, remediación, evidencia de re-prueba y decisiones de riesgo residual.

Capítulo 16 — Propiedad intelectual, cadena de valor e integración de componentes

La organización debería identificar componentes licenciados, propietarios, de terceros, open source y alojados externamente que influyen en el sistema. Deben documentarse cuando corresponda términos del proveedor, restricciones de uso, derechos sobre salidas, condiciones de tratamiento de datos y dependencias.

La revisión de cadena de valor debería incluir proveedores de modelos, alojamiento, conjuntos de datos, fuentes de recuperación, plugins, API, servicios de seguridad, monitoreo y subprocesadores. Un cuestionario de proveedor por sí solo no constituye evidencia suficiente para dependencias de alto riesgo. Cambios materiales de proveedor o componente deben activar reevaluación cuando puedan alterar capacidad, tratamiento de datos, exposición contractual, seguridad, disponibilidad o comportamiento de salida.

Capítulo 17 — Estrategia de evaluación

La evaluación comienza con una pregunta documentada: qué debe poder hacer el sistema, qué debe evitar, bajo qué condiciones y con qué nivel de confianza. La estrategia debería definir objetivos, escenarios, conjuntos de datos, evaluadores, métodos, umbrales, muestreo, limitaciones y reglas de decisión.

La evaluación debería incluir uso normal representativo y uso indebido plausible. Los sistemas de alto impacto deberían incorporar desafío independiente o separación entre quienes construyen y quienes toman la decisión final de liberación.

Capítulo 18 — Gobernanza de datos de prueba y escenarios

Los datos de prueba deberían ser trazables a su propósito. Los equipos deberían registrar origen, cobertura, sensibilidad, transformación, representatividad, limitaciones conocidas y si los datos pueden retenerse o compartirse.

Los datos sintéticos pueden mejorar cobertura, pero no deben asumirse representativos de poblaciones reales o comportamiento adversarial. Cuando se usen, el registro de evaluación debería indicar por qué son apropiados y qué puntos ciegos permanecen.

Capítulo 19 — Umbrales de aceptación y criterios de decisión

Los umbrales deberían establecerse antes de las pruebas finales cuando sea práctico y reflejar consecuencias, no conveniencia. Un asistente de redacción de bajo impacto puede tolerar tasas de falla distintas a un sistema que influya en decisiones de seguridad, finanzas, salud, empleo o protección.

La decisión de liberación debería registrar si cada umbral aprobó, falló, fue aceptado condicionalmente o fue eximido. Las exenciones requieren fundamento, responsable, control compensatorio, fecha de vencimiento o revisión y aprobación del riesgo residual.

Capítulo 20 — Red teaming y evaluación adversarial

La evaluación adversarial debería probar si los controles siguen siendo efectivos cuando usuarios o contenido externo intentan evadirlos deliberadamente. Los casos deberían abordar manipulación directa de prompts, instrucciones indirectas, envenenamiento de recuperación, abuso de herramientas, fallas de identidad o permisos, extracción de datos, revelación del prompt del sistema y encadenamiento inseguro de acciones cuando aplique.

Los resultados de red team deben tratarse como evidencia, no como exhibición. Pruebas repetidas sin responsable de remediación ni re-pruebas no deben representarse como aseguramiento.

Capítulo 21 — Controles de procedencia de contenido

La procedencia debería responder preguntas prácticas: qué modelo y configuración produjo la salida, qué datos o fuentes influyeron materialmente, qué transformaciones ocurrieron y quién o qué aprobó el uso posterior.

La organización debería seleccionar mecanismos proporcionales al riesgo, como enlaces a fuentes, hashes de artefactos, identificadores de modelo/versión, versiones de prompts o políticas, registros de transformación, aprobaciones humanas o metadatos firmados. La procedencia mejora trazabilidad, pero no prueba por sí sola exactitud factual u origen lícito.

Capítulo 22 — Paquete de pruebas previo al despliegue

Un paquete de evidencia previo al despliegue debería reunir lo necesario para una decisión responsable. Como mínimo debería incluir inventario del sistema/caso de uso, registro de riesgos e impactos, plan y resultados de evaluación, pruebas de seguridad/adversariales, revisión de privacidad/datos cuando aplique, evidencia de proveedores/componentes, hallazgos y excepciones abiertos, umbrales de monitoreo, plan de detener/revertir y registro de aprobación.

El paquete debe versionarse y vincularse con el candidato exacto de liberación.

Capítulo 23 — Preparación para divulgación y escalamiento de incidentes

Antes del despliegue, la organización debería definir qué eventos califican como incidentes de IA generativa, quién debe ser informado, qué evidencia debe preservarse y cuándo puede requerirse notificación o divulgación externa.

Las categorías pueden incluir salida dañina, exposición de datos, acción no autorizada, evasión de controles, falla de proveedor, desinformación material, autonomía inesperada, incumplimiento regulatorio o contractual o violación repetida de umbrales. Los criterios de escalamiento deberían ser suficientemente explícitos para evitar improvisación durante un evento.

Capítulo 24 — Suficiencia de evidencia y calidad de revisión

La evidencia debería demostrar que un control operó para el sistema y periodo pertinentes. Políticas, capturas de pantalla, afirmaciones de proveedores o cuestionarios pueden apoyar la evidencia, pero no deben tratarse automáticamente como prueba de efectividad.

Los revisores deberían considerar relevancia, confiabilidad, integridad, oportunidad e independencia. Cuando la evidencia sea débil o no esté disponible, el registro debe declarar esa limitación y su efecto sobre el riesgo residual o la confianza en la liberación.

Capítulo 25 — Controles de despliegue y liberación

El despliegue debería usar un registro controlado vinculado al artefacto probado, configuración, versión del modelo, estado de datos/recuperación, herramientas, guardrails y condiciones operativas aprobadas. Una desviación material entre el candidato probado y el sistema desplegado invalida la evidencia de liberación hasta ser evaluada.

Los registros deberían identificar aprobadores responsables, excepciones abiertas, umbrales de monitoreo, autoridad de reversión y fechas de revisión.

Capítulo 26 — Monitoreo y umbrales operativos

El monitoreo debería vincularse con riesgos conocidos y umbrales de decisión, no con telemetría genérica. Las medidas relevantes pueden incluir tasas de salida dañina, respuestas sin respaldo, eventos de seguridad, señales de fuga de datos, quejas de usuarios, fallas de herramientas, indicadores de drift del modelo, latencia/disponibilidad, cambios de proveedores y volumen de excepciones.

Las violaciones de umbral deberían mapearse a acciones predefinidas: investigar, restringir, aumentar revisión humana, deshabilitar una función, revertir o detener el sistema.

Capítulo 27 — Gestión de cambios y reevaluación

Los cambios en modelos, prompts, instrucciones del sistema, fuentes de recuperación, herramientas, permisos, tratamiento de datos, proveedores, guardrails, interfaces o uso de negocio pueden alterar el riesgo. Los registros de cambio deberían clasificar materialidad e identificar qué evidencia previa sigue siendo válida.

Los cambios materiales reabren las compuertas afectadas de riesgo, pruebas, seguridad, privacidad, accesibilidad, revisión humana y liberación. Los cambios de emergencia requieren revisión retrospectiva y completar evidencia dentro de un periodo definido.

Capítulo 28 — Respuesta a incidentes y contención

La respuesta a incidentes de IA generativa debería integrarse con la gestión empresarial de incidentes conservando evidencia específica de IA. Los equipos deberían capturar prompts, salidas, identificadores de modelo/configuración, contexto de recuperación, llamadas de herramientas, identidades, marcas de tiempo, registros, registros afectados, avisos de proveedores y estado de controles cuando sea lícito y factible.

Las opciones de contención pueden incluir deshabilitar herramientas, reducir permisos, aislar fuentes de recuperación, revertir configuración, limitar usuarios, aumentar revisión humana o suspender el servicio.

Capítulo 29 — Acción correctiva y validación de remediación

La acción correctiva debería abordar causas raíz y no solo suprimir la salida observada. Los registros deberían identificar hallazgo, causa, responsable, acción planificada, fecha objetivo, método de validación, evidencia, riesgo residual y decisión de cierre.

Una corrección no debe considerarse cerrada solo porque un caso de prueba ahora aprueba. La re-prueba debería evaluar variantes probables y riesgo de regresión.

Capítulo 30 — Revisión periódica e informes de gestión

La revisión periódica debería evaluar si el caso de uso sigue siendo apropiado, los controles siguen siendo efectivos, los supuestos de riesgo siguen siendo válidos, la evidencia está vigente, proveedores o componentes cambiaron y los resultados operativos permanecen dentro de tolerancia.

Los informes de gestión deberían distinguir hechos, tendencias, supuestos, riesgos no resueltos, excepciones aceptadas y decisiones requeridas. Los problemas de alto riesgo deberían ser visibles para el responsable de riesgo y no quedar enterrados en informes técnicos.

Capítulo 31 — Retiro, disposición de datos y salida

La planificación del retiro debería abordar endpoints de modelos, credenciales, prompts, índices de recuperación, almacenes vectoriales, registros, datos de usuarios, cachés, integraciones, acceso de proveedores, evidencia retenida y obligaciones contractuales.

La organización debería verificar devolución o eliminación de datos cuando corresponda, revocar accesos y secretos, deshabilitar integraciones, conservar registros requeridos, documentar obligaciones no resueltas y registrar la decisión de retiro.

Capítulo 32 — Aseguramiento, limitaciones y límite final de liberación

El aseguramiento es acumulativo y específico del alcance. QA del repositorio, pruebas automatizadas, red teaming, documentación o una lista de verificación completa no garantizan que un sistema de IA generativa sea seguro, protegido, conforme, exacto, equitativo o apto para todos los contextos.

Antes de publicar este manual, el paquete controlado debe completar verificación de fuentes, revisión técnica/editorial, revisión semántica es-419 y pt-BR, verificación de gráficos/accesibilidad, generación DOCX/PDF, QA a nivel de página, procedencia y checksums, revisión de repositorio/seguridad y Aprobación Humana Final de Liberación explícita.

Cualquier cambio material de contenido posterior a la aprobación humana reabre la compuerta de revisión afectada.